Ssense: A Browser-Native Small Language Model Architecture with a Deterministic Statutory Compliance Layer for Real-Time Privacy Policy Auditing and Network-Level Enforcement under India's DPDP Act, 2023

Anubhav Das
Department of (to be added)
Institute of Engineering and Management
India
email: (to be added)

Priyanshu Roy
Department of (to be added)
Institute of Engineering and Management
India
email: (to be added)

***Abstract*—India's Digital Personal Data Protection (DPDP) Act, 2023 gives people enforceable rights over their data, but few people read or understand the privacy policies through which organisations describe how they comply. The one DPDP policy checker we found, APLiance, prompts a hosted general-purpose language model to extract attributes, passes them to a symbolic rule engine, and reports results without changing what the browser does. We present Ssense, a browser-native auditing system built on a small language model adapted to the statute. Two LoRA adapters, a forensic auditor and a citizen-facing chatbot, are trained from Qwen2.5-7B-Instruct with rank-stabilised LoRA and Simple Preference Optimisation. A hybrid retrieval index over the Act grounds inference. Output is bound to a JSON schema with an omission gate that drops findings based on a policy's silence, and a deterministic Statutory Compliance Layer adds violations that a policy states outright. Confirmed findings become Manifest V3 network rules, header changes, fingerprinting countermeasures and a Global Privacy Control signal. In a pilot on ten Indian fiduciaries, the system confirmed three violations with no false positives or fabricated citations against the reference labels, although all three resulting actions were warnings. Because ten sites are statistically weak (a perfect score has a Wilson lower bound of 0.72), we state the limits of the pilot, analyse the published APLiance figures, survey the related literature, and give an 18-axis certification protocol and eight planned studies.**

Index Terms*—DPDP Act, privacy policy auditing, small language models, retrieval-augmented generation, preference optimisation, browser extension, regulatory compliance, network enforcement*

I. INTRODUCTION

India's Digital Personal Data Protection (DPDP) Act, 2023[1] gives data principals enforceable rights and places specific duties on the organisations that process their data, called data fiduciaries. The Rules issued under the Act[2] fill in procedure for notice, consent withdrawal, security safeguards and grievance handling, and the obligations are being phased in over a transition period. The Act applies to digital personal data processed inside India and, in some circumstances, to processing outside India that relates to offering goods or services to people in India. It follows the recognition of privacy as a fundamental right under Article 21 of the Constitution[3].

A fiduciary's privacy policy is the document in which it says what it does with personal data, so it is the obvious artefact against which compliance can be checked. In practice almost nobody checks. A PwC India survey of 3,233 consumers found that only 16% knew the DPDP Act existed and that 69% were unaware they could withdraw consent[4]. A survey of human-computer-interaction research on privacy finds that 45% of the 231 studies it selected had no user involvement [1], so evidence on what helps ordinary readers is thinner than the volume of tooling suggests.

Language models are an obvious candidate for closing this gap, but legal compliance raises two problems. The first is factual reliability. Dahl et al. [2] report that general-purpose models hallucinate on specific, verifiable questions about US federal courts at least 58% of the time for GPT-4 and 88% for Llama 2, and that the models often accepted false premises in the question. Those rates belong to their models and question design and should not be carried over to our system, but they motivate measuring statutory correctness, unsupported claims and abstention, not only fluency. The second problem is what we call *jurisdictional contamination*: a model trained mostly on European and American text can carry GDPR or CCPA concepts into an Indian setting where the statute says something different. A related failure is to treat a policy's silence as a violation, flagging an obligation as breached only because the policy does not mention it.

A. Limits of existing work

Few systems address the DPDP Act directly. APLiance (Dhakar, Sinha and Sural, arXiv:2604.10832, 2026) formalises Sections 1 to 7 of the Act as Attribute-Based Access Control (ABAC) rules, treats a policy as a set of implied access requests, and uses a hosted LLM (GPT-5.4-mini, without fine-tuning) to fill in sixteen attribute values from the policy text. A symbolic rule engine

[1]The Digital Personal Data Protection Act, 2023, Ministry of Electronics and Information Technology, Government of India. https://www.meity.gov.in/static/uploads/2024/06/2bf1f0e9f04e6fb4f8fef35e82c42aa5.pdf

[2]Digital Personal Data Protection Rules, 2025, Ministry of Electronics and Information Technology, G.S.R. 846(E), November 2025. The status of the Rules text used to build the corpus should be confirmed against the Gazette before submission.

[3]Justice K. S. Puttaswamy (Retd.) v. Union of India, (2017) 10 SCC 1, Supreme Court of India.

[4]PwC India, "How aware and prepared are Indian consumers and businesses to navigate the new era of digital privacy?" survey report, October 2024.

then returns the verdict. On 25 real policies it reports 94.5% attribute-level accuracy and finds none of them fully compliant. It is a preprint, and we found no peer-reviewed DPDP website-policy audit benchmark in the sources we surveyed. Indian legal language-model work exists, for example a LoRA-adapted model for the Indian legal system [3], but it does not evaluate website privacy notices against DPDP requirements.

Work outside India is richer but uses other laws. Systems label policy sentences against GDPR Article 13 [4], assess GDPR disclosure terms on web platforms [5], annotate CCPA disclosures [6], and compare declared practices with observed behaviour in browser extensions [7]–[9] and in cookies [10]. These studies use different laws, datasets and metrics, and none acts on its finding in the browser. We therefore treat them as architectural precedents and not as validation for the DPDP Act.

Three properties of the closest DPDP checker motivate our design. First, its extraction step relies on a general-purpose cloud model that has not been adapted to the statute, and its own results show that attributes depending on implicit wording are the weak point (64% accuracy for unambiguous consent, 76% for easy withdrawal). Second, policy text leaves the user's machine for a third-party backend and model API. Third, findings are reported but nothing changes in the browser.

B. Contributions

This paper presents Ssense, a browser-native auditing system for the DPDP Act. Its contributions are as follows.

1. **A dual-track fine-tuned small language model.** Two LoRA adapters share one Qwen2.5-7B-Instruct base: a forensic auditor (rank 128) that produces schema-bound audit reports and a citizen-facing chatbot (rank 64). Both are trained with supervised fine-tuning followed by Simple Preference Optimisation (SimPO).
2. **Statutory pruning to 26 enforceable violation types.** Provisions that regulate the Data Protection Board and the Appellate Tribunal are removed mechanically, leaving 26 violation types a fiduciary can commit, each tied to a section, a severity class and a network action in a decision tree.
3. **A Statutory Compliance Layer (SCL).** A deterministic regex layer with safe-harbour filters is unioned with the model's findings, so that violations stated outright in a policy are not lost to attention decay or negation errors.
4. **An omission firewall.** A three-step reasoning schema and a binary `omission_check` field remove any finding that rests on what a policy leaves unsaid.
5. **A path from finding to browser behaviour.** Confirmed violations become Manifest V3 `declarativeNetRequest` rules, header rewriting, fingerprinting-API countermeasures and a Global Privacy Control signal.
6. **A certification protocol and a pilot study.** An 18-axis release gate evaluated at Wilson lower bounds, and a pilot over ten Indian fiduciaries, reported with an explicit account of what ten sites can and cannot show.

We are careful about two claims. We do not claim to be the first DPDP compliance checker, because APLiance is. We also do not claim that the pilot establishes population-level accuracy; Section VIII shows that a perfect score on ten sites is statistically compatible with a true accuracy near 72%. The comparison with is made on design properties and on its published figures, and where the evaluation units differ we say so.

C. Organisation

Section II gives the legal and technical background. Section III surveys related work. Section IV analyses the research gaps. Section V formalises the legal mapping. Section VI describes the system. Section VII sets out the evaluation protocol, Section VIII reports and analyses results, and Section IX discusses them. Sections X and XI cover limitations and ethics, and Section XII concludes.

II. BACKGROUND AND PRELIMINARIES

A. DPDP Act provisions relevant to policy auditing

Table I lists the provisions that a privacy policy can plausibly breach through what it says. Sections 4 to 7 set out the lawful grounds for processing: consent that is free, specific, informed, unconditional and unambiguous (Section 6), the notice that must accompany a consent request (Section 5), and a closed list of legitimate uses that need no consent (Section 7). Section 8 covers a fiduciary's general obligations, including reasonable security safeguards, breach intimation and erasure when consent is withdrawn or the purpose is served. Section 9 restricts processing of children's data, including tracking and behavioural monitoring. Section 13 gives the data principal a right of grievance redress, and Section 16 governs transfers outside India. Sections 18 to 26 constitute and empower the Data Protection Board, and Sections 29 to 32 deal with appeals; these regulate state institutions and cannot be breached by a privacy policy.

TABLE I:
DPDP PROVISIONS THAT BEAR ON PRIVACY-POLICY CONTENT

Section	Obligation (paraphrased)	Typical policy defect
5(1), Rule 3	Itemised notice before or with the consent request	Missing purpose, data categories or rights information
6(1), 6(4)	Consent free, specific, informed; withdrawal as easy as giving	Bundled consent; withdrawal only by email or letter
7	Closed list of legitimate uses without consent	Broad commercial rights claimed as “legitimate use”

Section	Obligation (paraphrased)	Typical policy defect
8(5), 8(7)	Security safeguards; erasure once purpose is served	Retention “indefinitely”; no safeguards described
9	Verifiable parental consent; no tracking of children	Behavioural advertising reaching minors
13	Accessible grievance redress	No contact route for complaints
16	Transfers outside India limited by notification	Unrestricted transfer to foreign affiliates

B. Notation and the ABAC view of compliance

Compliance checking can be framed as an access-control decision. In ABAC, as used in APLiance, a request is a tuple of subject, object, action and environment attributes, and a policy function returns permit or deny. APLiance uses this to ask whether the data operations implied by a privacy policy would be permitted by rules derived from the law. It separates base attributes (read from the policy text), derived attributes (computed by rules) and unknown attributes (runtime facts the policy cannot settle), and it calls a request admissible only if it is permitted under every value an unknown attribute could take. This is a conservative treatment of missing information. Ssense takes a different position on silence, set out in Section V, and the difference matters when comparing outcomes.

C. Adapters and preference optimisation

A small language model here means a model in the 7-billion-parameter class that can be served on a single accelerator. Qwen2.5-7B-Instruct (Qwen Team, 2024) is a decoder-only Transformer with grouped-query attention, rotary position embeddings, SwiGLU feed-forward layers and RMSNorm. It has 28 layers, which matters for the memory partitioning in Section VI. Low-rank adaptation (LoRA) [11] freezes the base weights and learns a low-rank update to selected matrices, which makes it practical to keep several task-specific adapters over one base model. Rank-stabilised LoRA (Kalajdzievski, arXiv:2312.03732) changes the scaling of the update from the conventional ratio of alpha to rank to the ratio of alpha to the square root of rank, which the original analysis shows keeps learning stable as rank grows.

For alignment we use Simple Preference Optimisation [12]. Direct preference optimisation [13] and contrastive preference optimisation [14] compare a policy against a frozen reference, which doubles the models held in memory during training. SimPO scores each response by its length-normalised log-likelihood under the policy being trained and adds a target margin, so no reference model is needed. We use it because the preference pairs here encode a specific distinction (schema-valid and grounded versus fabricated or over-called), and because the memory saving matters on a single training node. SimPO does not by itself make an answer legally correct, a point we return to in Section IX.

D. Retrieval and structured output

Retrieval-augmented generation [15] separates a model's stored knowledge from an updateable evidence store, which suits a statute that is amended by rules and where each answer should carry provenance. Sparse retrieval with BM25 matches exact terms such as section numbers, dense retrieval with embeddings matches paraphrases [16], and a cross-encoder re-scores the shortlist jointly with the query. Grammar-constrained decoding restricts the tokens a model may emit, which we use to guarantee that audit reports are well-formed JSON.

III. LITERATURE SURVEY

We survey work in the order of the Ssense pipeline: legal adaptation, synthetic data and alignment, retrieval, privacy-policy compliance and runtime monitoring, human factors, and safety, followed by the DPDP-specific systems. Most of the sources were read at abstract level, so we report what the authors state and do not re-derive their results. Reported scores are not pooled, because the legal regimes, datasets, tasks and metrics differ. Table II maps each evidence line to what it supports in Ssense and where the transfer stops.

TABLE II:
EVIDENCE MAP: WHAT THE LITERATURE SUPPORTS AND WHERE TRANSFER STOPS

Evidence line	Method	Supports in Ssense	Transfer limit
Legal adaptation [2], [3], [11], [17]–[21]	Domain pre-training, low-rank adaptation, legal instruction data, hallucination profiling	Adapter design; broad regression suite; abstention and entailment measures	No DPDP-specific validation; other jurisdictions and tasks
Synthetic data and judges [22]–[27]	Generate–filter pipelines, teacher–student transfer, rubric judges, model collapse	Data Forge design; real-policy retention; independent validation	Teacher output is not ground truth; judge scores are task-specific
Preference alignment [12]–[14], [28]	Reference-based and reference-free objectives; factuality-aware alignment	SimPO phase; factuality-oriented rejected samples	Preference gains do not prove legal correctness
Retrieval [15], [16], [29]	Retrieve-then-read, dense search, late interaction	Statute lookup and re-ranking for the chatbot	General question answering, not statutory entailment
Compliance and runtime [4]–[10], [30]–[35]	Rule inventories, sentence labelling, entailment, disclosure-versus-traffic comparison	Clause-to-evidence mapping; runtime evidence for enforcement	Mostly GDPR or CCPA; non-comparable metrics
Human factors and safety [1], [36]–[41]	User studies, interactive assessment, injection benchmarks and defences	Comprehension and trust measures; adversarial tests	Usability and injection robustness are measured separately

Evidence line	Method	Supports in Ssense	Transfer limit
DPDP-specific (APLiance preprint)	Attribute-based rule checker with a hosted LLM	Problem framing and design contrast	One preprint checker; no peer-reviewed DPDP benchmark found

A. Legal-domain adaptation and evaluation

The first question is whether a general model can acquire legal vocabulary and task structure without being mistaken for a jurisdiction-aware reasoner. LEGAL-BERT compared a general BERT, continued pre-training on legal text and pre-training from scratch, which makes domain adaptation a baseline to beat and not a guarantee of transfer [17]. LoRA [11] is the adaptation pattern behind Ssense's two adapters. Two recent applications pair low-rank or quantised adaptation with local legal text: one targets the Indian legal system [3] and one legal question answering based on LoRA [18]. Both demonstrate applications; neither evaluates compliance with the DPDP Act or its Rules.

The strongest evidence for legal instruction data is LawInstruct, which gathers 58 annotated legal datasets into 12 million examples across 17 jurisdictions and 24 languages and reports that legal-specific Flan-T5 models improve on LegalBench without a reported loss on MMLU [19]. This supports multi-task legal fine-tuning with a broad regression suite, but jurisdictional diversity is not a substitute for testing on Indian statutes. An evaluation of legal judgment prediction finds that retrieved similar cases and label options help models recover task-relevant knowledge, while a strong retriever alone can sometimes beat the combined LLM-and-retrieval pipeline [20]. For answers addressed to citizens, LLeQA supplies 1,868 expert-annotated questions on French law and evaluates a retrieve-then-read system [21]; its expert grounding is a useful benchmark-design precedent, not evidence about Indian law.

Output risk is not only a retrieval problem. Dahl et al. [2] profile hallucinations on specific, verifiable questions about US federal courts and report rates of at least 58% for GPT-4 and 88% for Llama 2, with frequent acceptance of incorrect premises. The rates apply to those models and questions. They motivate our evaluation of statutory correctness, unsupported claims, abstention, and whether a cited provision actually entails the stated conclusion.

B. Synthetic data, evaluation by models, and alignment

Self-Instruct set out a generate, filter and fine-tune pattern: a model writes instructions and responses, and invalid or near-duplicate items are removed before training [22]. A 2025 survey of synthetic-data generation names the matching trade-off, since generated text widens coverage where labels are scarce but brings factual error, distribution mismatch and bias that need quality checks [23]. Legal question answering now tests the teacher–student version directly: Italiani et al. use a frozen teacher to generate legal questions and answers for a smaller student and retrieve the relevant document [24]. That setting is Italian law, and its synthetic corpus is not independent ground truth, so it supports our approach but cannot validate statute-derived violation labels. Training on recursively generated text can also make the tails of the data distribution disappear [27], which is why real, reviewed policies should remain in the training mix.

Models can score text, but they are not self-validating. G-Eval reports a Spearman correlation of 0.514 with human ratings on summarisation and notes a possible preference for model-written text [25]. Prometheus scores long answers against custom rubrics and reports a Pearson correlation of 0.897 with human evaluators [26]. The two coefficients use different tasks and statistics and should not be compared. For a data-curation loop, rubric scores are one signal, to be checked by independent rules and expert review.

Preference optimisation shapes behaviour but does not establish legal correctness. DPO [13], contrastive preference optimisation [14] and SimPO [12] are distinct baselines; SimPO uses a reference-free, length-normalised sequence reward. FLAME examines factuality-aware alignment and reports that conventional alignment can reward longer, more helpful-sounding answers even when they add false statements [28]. For legal guidance, the preference signal has to reward statutory entailment and correct uncertainty, not confidence or length, so the alignment stage should be evaluated with statute-level factuality and omission measures as well as pairwise preference accuracy.

C. Retrieval and legal grounding

Retrieval-augmented generation keeps knowledge in an updateable store and gives answers provenance [15]. Dense passage retrieval is a dual-encoder baseline that was compared directly with BM25 [16], and ColBERT shows that late interaction can rank passages efficiently [29]. They support a hybrid sparse-and-dense pipeline with a re-ranker, but a high retrieval score does not show that the chosen passage supports the generated judgement. The retrieve-then-read systems of [21] and [24] point to evaluating retrieval recall and answer-to-statute entailment separately.

The distinction between closed-book and open-book use matters for Ssense. The auditor is trained without the law in its prompt, so it must generalise from synthetic examples to provisions it has not seen, whereas the chatbot retrieves current law at inference. Evidence for the second architecture does not establish the first capability, so the adapters need separate tests: held-out DPDP provisions for the auditor, and retrieval relevance, citation correctness and entailment for the chatbot.

D. Privacy-policy compliance and runtime auditing

Early compliance systems turned legal requirements into sentence labels and rules. Liu et al. combined sentence classification with rules for GDPR Article 13 and built a corpus of 36,610 labelled sentences from 304 policies [4]. CompLicy translated GDPR disclosure requirements into 89 terms in seven groups and assessed 148 web platforms [5]. Both show that compliance

needs an explicit rule inventory and traceable policy evidence; a free-form summary does not establish that a required disclosure is present.

Browser extensions make the gap between policy and practice measurable. Ling et al. compare policies and regulatory requirements with extensions' runtime behaviour and report that about 92% of the extensions examined had at least one privacy violation [7]. ExtPrivA analyses extension-triggered network requests for inconsistencies with disclosures, reporting 85% precision and 820 inconsistent extensions among 47,200 [8]. MINDAEXT asks about data minimisation: among roughly 200,000 extensions, 38.0% were likely to collect more than essential functionality needs, with 74.3% detection precision [9]. These studies compare disclosures with observed data flows, which is the closest precedent for measuring what Ssense's network rules do. They do not show that blocking a request is safe or complete.

Recent systems are finer-grained. C3PA labels policy segments against CCPA disclosure requirements [6]; PrivComp-KG retrieves policy excerpts and maps them to regulatory rules [30]; and Huang et al. use AI chatbots to produce structured annotations of corporate privacy practices for an Internet-measurement study [35]. A reasoning framework for healthcare services assesses GDPR Article 13 by sliding-window entailment and rule aggregation, and was tested on 388 synthetic healthcare policies and 100 websites [31]. A GKC-CI study fine-tunes models on 21,588 annotations from 16 policies, reports 90.65% accuracy for its best model, and applies it to 456 policies [32]. Cory et al. annotate 21 GDPR transparency requirements at word level, with a 200-policy manually annotated sample [33]. Vu and Ha compare declared cookie attributes with observed browser behaviour and find undeclared cookies and deployment before consent [10], and Wang et al. detect compliance problems in mobile-application policies with an LLM-based method [34]. Table III lists the scale and evidence type of these studies. Each measures different rules, samples and annotation units, so their joint contribution is methodological, finer granularity and runtime evidence, not a transferable score for the DPDP Act.

TABLE III:
COMPLIANCE-CHECKING STUDIES COMPARED (FIGURES AS REPORTED BY THE AUTHORS)

Study	Law or target	Scale and headline figure	Evidence type
Liu et al. [4]	GDPR Art. 13	36,610 labelled sentences, 304 policies	Sentence classification plus rules
CompLicy [5]	GDPR	89 terms in 7 groups; 148 web platforms	Rule inventory
Ling et al. [7]	Extension practices	About 92% of examined extensions with at least one violation	Policy and runtime comparison
ExtPrivA [8]	Extension traffic	47,200 extensions; 820 inconsistent; 85% precision	Network-request analysis
MINDAEXT [9]	Data minimisation	About 200,000 extensions; 38.0% beyond essential; 74.3% precision	Description versus collection
Chen et al. [31]	GDPR Art. 13	388 synthetic policies; 100 websites	Sliding-window entailment
GKC-CI [32]	Contextual integrity	21,588 annotations, 16 policies; 90.65% accuracy; applied to 456 policies	Fine-tuned classifiers
Cory et al. [33]	GDPR transparency	21 requirements; 200-policy annotated sample	Word-level LLM annotation
APLiance	DPDP §§1–7	25 policies; 400 pairs; 94.5% accuracy	Prompted LLM plus symbolic rules

E. Human factors and user trust

Usability and trust have to be measured as well. A 2025 survey of human-centred privacy research selected 231 studies from 8,867 records and found that 45% involved no users [1]. A browser-extension study of interactive policy assessment with 22 participants found that summaries and chat improved awareness while raising trust concerns [36]. Privacy2Practice evaluates structured extraction of entities, data types and purposes [37], and PrivacyCheck v3 adds policy-change tracking and comparison [38]. Together they support a citizen-facing layer beside the forensic audit and argue for measuring comprehension and trust separately from technical accuracy.

F. Safety and prompt injection

Prompt injection is a system-level risk whenever a model consumes fetched or retrieved text, as an auditor reading policy pages does. Greshake et al. show how retrieved content can override intended instructions in LLM-integrated applications [39]. Li et al. benchmark whether instruction-following models separate the intended task from embedded instructions [40], and SecAlign uses preference optimisation to train secure responses, reporting injection success below 10% in its evaluated settings [41]. None of these studies covers the mixture of hostile policy text, statute excerpts and browser traffic that Ssense sees, so adversarial tests belong in its own certification.

G. DPDP-specific systems

APLiance is the one DPDP policy checker we found. Its formalism has three attribute classes and eleven decision and derivation rules, and a hosted backend serves a browser extension with a 24-hour result cache. Its evaluation uses 25 policies from e-commerce, social media, news and streaming organisations with 16 attributes each, giving 400 labelled pairs. The published confusion matrix has 272 true positives, 106 true negatives, 11 false positives and 11 false negatives, so accuracy is 94.5% and precision and recall are both 96.1%. Explicitly stated requirements such as purpose and lawful purpose are classified perfectly, while consent_is_unambiguous (accuracy 0.64, recall 0.14) and easy_consent_withdrawal (accuracy 0.76) are hard. An ablation

shows that decomposing the task into attributes beats asking the model for a verdict directly (76% against 68% on withdrawal, 64% against 52% on unambiguous consent). No policy is compliant on the full rule set; after relaxing three attributes (notices and consent requests in all Eighth Schedule languages, and a route for complaints to the Board), three of 25 pass, and after also relaxing two ambiguous consent attributes, 20 of 25 pass. The authors list wider section coverage and multilingual support as future work.

Relation to Ssense. Ssense inherits the problem statement from APLiance and its idea of decomposing compliance into structured intermediate decisions, but replaces the prompted extractor plus symbolic engine with an adapted model whose output is constrained and cross-checked by deterministic rules. It adds a chatbot and a route to enforcement, which none of the sources above provide, and it takes evaluation ideas from fine-grained annotation studies [32], [33] and from runtime comparison studies [8], [9].

IV. RESEARCH GAP ANALYSIS

Table IV compares representative systems on the properties that matter for a DPDP auditing tool; entries reflect our reading of the published descriptions and a dash means not applicable or not described. Table V states seven gaps and the design response to each. Table VI lists gaps that Ssense does not close, so that the contribution is not overstated.

TABLE IV:
CAPABILITY COMPARISON WITH REPRESENTATIVE PRIOR SYSTEMS

System	DPDP-specific	Domain-tuned model	Law-to-evidence mapping	Hallucination control	Runs in browser	Acts on findings	Citizen Q&A
Liu et al. [4]	No	Trained classifier	Yes (Art. 13)	Rule layer	No	No	No
Extension audits [7], [8]	No	—	Disclosure vs. traffic	—	No	No	No
Cory et al. [33]	No	No (LLM annotation)	Yes (21 requirements)	—	No	No	No
Interactive assessment [36]	No	No (LLM)	No	—	Yes (ext.)	No	Yes
APLiance	Yes (§1–7)	No (prompted)	Yes (attributes)	Symbolic verdict	Yes (remote)	No	No
Ssense	**Yes (26 types)**	**Yes (SFT + SimPO)**	**Yes (tree)**	**Omission gate + SCL**	**Yes**	**Yes**	**Yes**

TABLE V:
RESEARCH GAPS AND SSENSE DESIGN RESPONSES

Gap	What is missing in prior work	Ssense response
RG-1	**Findings are not acted on.** Policy checkers and extension audits report or measure; browser behaviour for the audited site stays unchanged [7], [8], [10].	Violation-to-action mapping in the decision tree; Manifest V3 rules, header changes, API countermeasures, GPC signal (Section VI-H).
RG-2	**No statute-adapted model for the DPDP Act.** Indian legal adaptation exists [3] and the closest DPDP checker prompts a general model; compliance corpora use GDPR or CCPA [4], [6], [33].	Qwen2.5-7B with rsLoRA adapters, SFT then SimPO, trained on statute-grounded synthetic pairs (Section VI-C).
RG-3	**Held-out statute generalisation is untested.** A closed-book auditor must handle provisions it has not seen; retrieval benchmarks do not test this [19], [21].	Separate tests for auditor (held-out provisions) and chatbot (retrieval, citation, entailment); study E2.
RG-4	**Synthetic data and model judges are not self-validating.** Judge agreement is task-specific [25], [26] and recursive generation can erode distribution tails [27].	Rule-based filter, real policy excerpts retained, contamination check; rubric judges only as an extra signal (Section VI-C).
RG-5	**Silence and omission are handled implicitly.** Unknown attributes are treated conservatively, or the issue is not discussed.	Explicit `omission_check`; findings from silence are dropped; semantic difference analysed (Sections V and VIII).
RG-6	**Injection robustness is not evaluated for policy auditors.** Benchmarks cover general applications [39]–[41].	Input hardening, schema repair and an injection axis in the certification matrix (Section VI-J).
RG-7	**Citizen explanation lacks statute grounding and user evidence.** Many HCI studies of privacy tools lack users [1], and interactive assistants are not tied to a statute [36].	Chatbot adapter over the stored audit and statute context; comprehension study E5 (Section VI-I).

TABLE VI:
GAPS THAT SSENSE DOES NOT CLOSE

Gap	Description	Status
Multilingual notices	Policies in Eighth Schedule languages are dropped at extraction; APLiance found none of 25 policies met the all-language requirement.	Future work (Section XII)
Public benchmark	No peer-reviewed benchmark of DPDP policy audits was found in the surveyed sources; our pilot has 10 sites.	Planned study E1 (Table XX)

Gap	Description	Status
User outcomes	No measured effect on user comprehension or on site breakage.	Planned studies E4, E5
Rule coverage	Sections beyond the 26 types, and Rules still being finalised, are not encoded.	Corpus refresh before release
On-device inference	A GGUF export exists but the evaluated path is server-side.	Future work
Component validation	The JSON-schema gate, omission firewall, MinHash contamination test, Wilson certification and 4-bit GGUF configuration are not yet isolated by ablation.	Study E2

V. LEGAL FORMALISATION

A. From 44 sections to 26 enforceable violation types

Not every section of the Act can be breached by the content of a privacy policy. Sections 18 to 26 constitute the Data Protection Board and set out its powers and procedure, and Sections 29 to 32 deal with appeals before the Appellate Tribunal. Let S_total be the set of 44 sections, S_admin the Board provisions and S_tribunal the appeal provisions. The set of provisions a fiduciary can breach is

$$\mathcal{P}_{enforce} = \mathcal{S}_{total} \setminus (\mathcal{S}_{admin} \cup \mathcal{S}_{tribunal}) \tag{1}$$

and the sections in this set are grouped into 26 named violation types. A decision tree built from the statute stores, for every type, the governing section, a severity class and a network action. At inference time the section cited in a report is looked up from the tree, not generated by the model, which removes one route to fabricated citations. The schema enumerates the 26 types; Table VII lists the 18 documented in the project methodology, grouped by the part of the Act they come from.

TABLE VII:
DOCUMENTED VIOLATION TYPES BY GROUP

Group	Violation types
Consent defects	`CONSENT_NOT_FREE_OR_SPECIFIC`, `CONSENT_MECHANICS_VIOLATION`, `CONSENT_MANAGER_OBSTRUCTION`
Purpose and retention	`PURPOSE_LIMITATION_VIOLATION`, `DATA_RETENTION_LIMIT_EXCEEDED`, `ERASURE_NOTICE_PERIOD_VIOLATION`
Special categories	`CHILD_CONSENT_VIOLATION`, `CROSS_BORDER_TRANSFER_VIOLATION`, `SDF_DATA_LOCALIZATION_VIOLATION`
Security and accountability	`SECURITY_SAFEGUARDS_MISSING`, `BREACH_NOTIFICATION_FAILURE`, `PROCESSOR_ACCOUNTABILITY_VIOLATION`
Rights and redress	`GRIEVANCE_REDRESSAL_INADEQUATE`, `RIGHTS_IMPLEMENTATION_VIOLATION`, `APPEAL_PROCESS_VIOLATION`
Systemic	`ALGORITHMIC_PROFILING_SDF`, `SCOPE_APPLICATION_EVASION`, `BOARD_COMPLIANCE_VIOLATION`

The remaining types of the 26 are enumerated in the repository schema (`dpdp_schema.json`) and will be listed in full once the section mapping has been audited against the statute text.

B. Violation-to-action mapping

Each confirmed violation maps to one of five actions. The assignment is intentionally uneven. Conduct that exposes data immediately and irreversibly, such as tracking children or transferring data abroad without authority, maps to a blocking action. Conduct whose remedy is organisational, such as an inadequate notice or retention without a limit, maps to a warning, because blocking a request would break the site without protecting the user any further. Table VIII gives representative mappings; the decision tree is the authoritative source.

TABLE VIII:
REPRESENTATIVE STATUTE-TO-ACTION MAPPINGS

Section	Violation type	Class	Action
5(1), Rule 3	`NOTICE_INADEQUATE`	Warn	`WARN_USER_ONLY`
6(1)	`CONSENT_NOT_FREE_OR_SPECIFIC`	Block	`BLOCK_THIRD_PARTY`
8(5)	`SECURITY_SAFEGUARDS_MISSING`	Warn	`WARN_USER_ONLY`
8(7)	`DATA_RETENTION_LIMIT_EXCEEDED`	Warn	`WARN_USER_ONLY`
9(1)	`CHILD_CONSENT_VIOLATION`	Block	`BLOCK_THIRD_PARTY`
13(1)	`GRIEVANCE_REDRESSAL_INADEQUATE`	Warn	`WARN_USER_ONLY`
16(1)	`CROSS_BORDER_TRANSFER_VIOLATION`	Block	`BLOCK_THIRD_PARTY`

C. Silence is not a breach

Ssense treats an affirmative claim in the policy as the only admissible basis for a violation. If a policy does not mention cross-border transfer, the system does not report a transfer violation, because the policy has not said that any transfer occurs. If the policy states that data is kept "indefinitely", that is an affirmative claim that can be matched to Section 8(7). This is a design decision with a cost: a fiduciary that omits a notice element required by Section 5 is not penalised by the omission gate for the omission alone. The notice-adequacy type remains available when the policy affirmatively describes a practice that conflicts with the notice requirements. APLiance makes the opposite choice for attributes the policy leaves unspecified, treating a request as violating if any admissible value of an unknown attribute would lead to denial. Neither choice is neutral, and Section VIII analyses how the choice changes what "compliant" means.

D. Scoring

Every report carries a trust score and a subtlety score, both in the range 0 to 100. The trust score starts at 100 and decreases with each confirmed violation by a weight w that depends on the severity class s(v) of the violation type:

$$T = \max\left(0,\ 100 - \sum_{v \in V_{final}} w_{s(v)}\right) \tag{2}$$

The weights are set in the system configuration. The subtlety score estimates how effectively violating text is disguised in legal phrasing, and is reported separately because a short, plainly worded violation and a long, carefully worded one can have the same trust score yet pose different risks to a reader.

VI. SYSTEM DESIGN

A. Overview

Ssense has four independently deployable parts: a Manifest V3 browser extension that holds no model weights and no raw policy text; an inference server; an offline training pipeline; and an enforcement layer inside the extension. The extension sends the server only a domain name and a policy URL, and the server returns a compact JSON report. Fig. 1 shows the data flow and Fig. 2 the training pipeline.

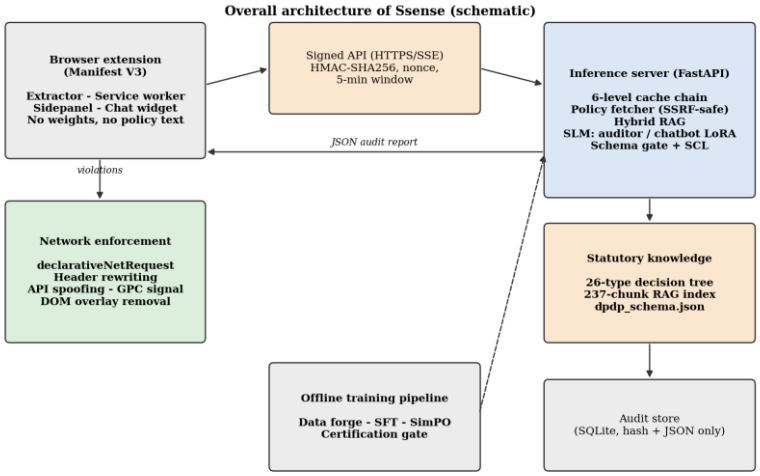


Fig. 1. Overall architecture of Ssense (schematic drawing; to be replaced by the final diagram).

B. Statutory corpus and hybrid retrieval

The corpus contains the 44 sections of the Act and the accompanying Rules, with cross-references between provisions mapped by hand. It is split at structural headers into 237 chunks, and each sub-chunk keeps its parent header so that a retrieved fragment still names the section it belongs to. Two indices are built. A BM25 index serves exact statutory wording and section numbers. A dense index of `BAAI/bge-large-en-v1.5` embeddings[5] serves paraphrase, so that "withdrawing permission easily" can retrieve the text on withdrawal of consent. For a query q and chunk c the hybrid score is a convex combination of max-normalised scores:

$$S_{hyb}(q,c) = \alpha \frac{S_{BM25}(q,c)}{\max_i S_{BM25}} + (1-\alpha)\frac{S_{BGE}(q,c)}{\max_j S_{BGE}} \tag{3}$$

[5]Embedding model BAAI/bge-large-en-v1.5. https://huggingface.co/BAAI/bge-large-en-v1.5

The top K candidates are then re-scored jointly with a cross-encoder (`bge-reranker-v2-m3`[6]):

$$S_{final} = \text{CrossEncoder}(q,\ \text{Top}K_{hyb}(C)) \tag{4}$$

Selection of the top K uses an O(N) partial sort rather than a full sort, and a bounded 2,048-entry LRU cache holds query embeddings so repeated queries are not re-encoded. Dense retrieval can improve on BM25 for open-domain questions [16], and late-interaction models such as ColBERT [29] trade index size for finer matching; we keep a single-vector index and add a cross-encoder instead. We use a convex combination, not reciprocal rank fusion, because score magnitudes carry information about exact section hits that rank-only fusion discards; we have not compared the two empirically. The retrieval design follows the retrieval-augmented generation paradigm [15]. The weighting factor alpha was set to 0.45 in the project notes.

C. Synthetic data, training and alignment

No labelled corpus of DPDP policy audits exists, so training pairs are synthesised with a generate, filter and retry loop that follows the self-instruction pattern [22]. A Qwen2-72B-Instruct teacher (FP8 weights) receives a real policy excerpt and the retrieved statutory context and writes an audit that conforms to the schema, with a few worked examples in the prompt to fix the format. A recent study of legal question answering uses a frozen teacher together with retrieval of the governing document for the same purpose [24].

A rule-based filter then discards any sample that fails schema validation, sets the omission flag, or cites a section absent from the statute. A rejected sample is regenerated within a small retry budget. We call this stage the Data Forge. The project documentation also refers to it as a generative-adversarial forge, but the filter is a fixed rule set and not a discriminator trained jointly with the generator, so the stage is synthetic-data curation and not adversarial training. Its practical risks are therefore label error, repetition and distribution drift [23]. Real policy excerpts stay in the mix for that reason, because training only on model-generated text can erase the tails of a data distribution [27].

For preference learning, a second pass inserts subtle weaknesses (for example a hidden retention period or vague grievance wording) into otherwise compliant policy text. Audits that over-call, under-call or fabricate on such text become the rejected member of a pair, and the filtered audits become the chosen member. Records are written in ChatML with the loss restricted to the assistant turn. A MinHash 7-gram similarity check using locality-sensitive hashing confirms zero overlap between the training and evaluation splits before any certification run. Rubric-based LLM judges [25], [26] could add a further quality signal, but their agreement with human raters is task-dependent and they may favour model-written text [25], so they would complement and not replace the rule checks and expert review. Fig. 2 summarises the pipeline.

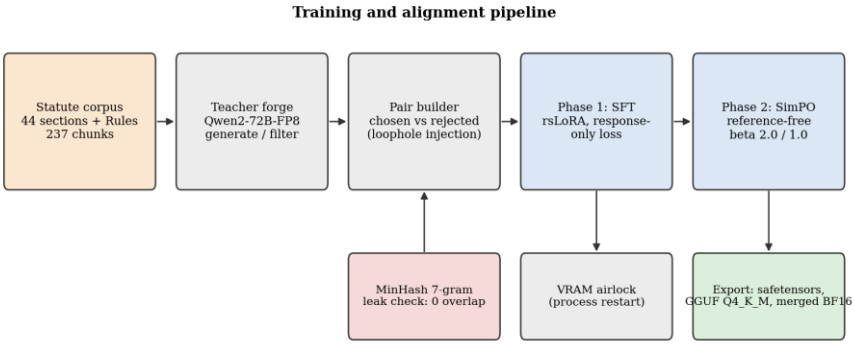


Fig. 2. Training and alignment pipeline: data forge, SFT, SimPO and export.

Two LoRA adapters [11] share the base weights and are hot-swapped at serving time (Table IX). Both use rank-stabilised scaling (Kalajdzievski, arXiv:2312.03732), in which the update is scaled by alpha divided by the square root of the rank:

$$\Delta W = \frac{\alpha}{\sqrt{r}} AB \tag{5}$$

With alpha 32 and rank 128 the effective scale is about 2.83 for the auditor, and with alpha 16 and rank 64 it is 2.0 for the chatbot. Conventional scaling would give 0.25 for both, which damps learning at high rank (Kalajdzievski, 2023).

TABLE IX:
ADAPTER SPECIFICATION

Property	Forensic auditor	Conversational chatbot
Task	Policy audit to validated JSON	Citizen guidance and rights dialogue
Context window	8,192 tokens	4,096 tokens
Output format	`dpdp_schema.json`	Markdown

[6]Re-ranker BAAI/bge-reranker-v2-m3. https://huggingface.co/BAAI/bge-reranker-v2-m3

Property	Forensic auditor	Conversational chatbot
LoRA rank / alpha	128 / 32	64 / 16
Target modules	All linear projections	All linear projections
SimPO beta	2.0 (strict, schema-bound)	1.0 (fluency preserved)
Artifact	`audit-model-final-adapter`	`chatbot-model-final-adapter`

Phase 1: supervised fine-tuning. Training uses FP32 AdamW over BF16 base weights, causal language modelling on response-masked sequences, and a split balanced across statutory sections so that frequent provisions such as Section 6 do not dominate. The Unsloth framework[7] (version 2026.8) supplies fused kernels, and the 4-bit memory techniques follow QLoRA. Training ran on an NVIDIA DGX Spark (Grace–Blackwell GB10, CUDA 13.0, PyTorch 2.11.0, BF16). The teacher model is fully unloaded and CUDA memory cleared before student training begins, which avoids fragmentation between phases.

Phase 2: SimPO. Alignment uses SimPO [12], which scores a response by its length-normalised log-likelihood under the policy and so needs no frozen reference model:

$$\mathcal{L}_{SimPO} = -\mathbb{E}\left[\log \sigma\left(\frac{\beta}{|y_w|}\log \pi_\theta(y_w|x) - \frac{\beta}{|y_l|}\log \pi_\theta(y_l|x) - \gamma\right)\right] \tag{6}$$

Here y_w is the chosen and y_l the rejected response, beta scales the reward and gamma is the target margin. Reference-based methods such as DPO [13] and contrastive preference optimisation [14] are the natural baselines for this stage. Work on factuality-aware alignment [28] warns that preference training can reward longer, more confident answers even when they contain false statements, which is why our rejected samples are fabricated and over-called audits and not merely differently styled ones. A larger beta for the auditor (2.0) sharpens the preference for schema-valid, grounded audits, while the chatbot uses 1.0 to preserve fluency. Both adapters are exported as safetensors for vLLM, as GGUF Q4_K_M for edge devices (executed with `llama.cpp`[8]), and merged into BF16 weights.

D. Output contract, omission firewall and Statutory Compliance Layer

The auditor's output must satisfy a fixed JSON schema with four top-level fields: a legal-reasoning narrative, a list of violations, a trust score and a subtlety score. Every violation passes through three ordered steps. Step 1 checks that the finding rests on an affirmative claim in the text. Step 2 maps the quoted evidence to a statute provision. Step 3 explains why the claim breaches that provision. A binary `omission_check` field is set when the finding derives from silence, and any finding with the flag set is removed before the report leaves the server (Fig. 3). Decoding is additionally restricted by a grammar so that the model can only emit syntactically valid JSON. A post-processor then clamps scores to the range 0 to 100, drops violation types outside the 26-type enumeration, and drops findings whose evidence quote is shorter than 20 characters.

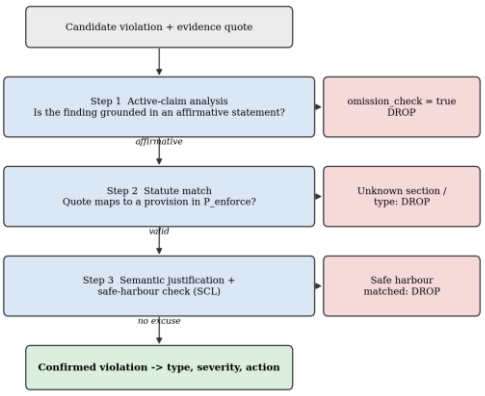


Fig. 3. Three-step reasoning chain and the places where a candidate finding is dropped.

A language model can miss a plainly stated violation because of negation errors or attention decay over a long policy. The Statutory Compliance Layer is a deterministic post-processor that holds, for each violation type v, a violation pattern R_v and a safe-harbour pattern H_v that legally excuses the matched behaviour (for example retention “unless required by law”). The final set is

$$V_{final} = V_{SLM} \cup \{ v \in V_{SCL} \mid \text{match}(\mathcal{P}_{text}, R_v) \wedge \neg \text{match}(\mathcal{P}_{text}, H_v) \} \tag{7}$$

[7]D. Han, M. Han and the Unsloth team, Unsloth: fast and memory-efficient LLM fine-tuning. https://github.com/unslothai/unsloth

[8]llama.cpp: LLM inference in C/C++. https://github.com/ggml-org/llama.cpp

so a regex hit can add a violation the model missed, but it cannot override the omission gate or the schema. We state plainly what the union does and does not provide. It adds recall for explicitly worded breaches, and the safe-harbour patterns limit the false positives that such additions could cause. It is not a formal guarantee of zero error, and its quality depends on the pattern sets, which are written by hand. The pilot in Section VIII measures its effect only indirectly, because we have not yet run the SCL-off ablation.

E. Inference server and layered caching

The server is a FastAPI application that probes the hardware at start-up and selects one of three profiles: `gpu` (vLLM with continuous batching and PagedAttention[9]), `jetson` (vLLM tuned for unified memory) and `cpu` (Transformers with PEFT). The GPU profile serves 8,192-token sequences with an FP8 KV cache on Hopper, Ada and Blackwell parts, prefix caching, chunked prefill, and two resident plus four CPU-resident LoRA slots with a maximum rank of 128. Every audit request passes through six lookups before any model is invoked (Fig. 4): an in-process LRU-TTL cache (512 entries, five-minute TTL); a SQLite audit store keyed by domain (90-day TTL); a SHA-256 policy-hash shortcut that reuses a stored audit whenever the policy text is unchanged; a server-side fetch and extraction; a re-check of the fresh hash against the stored hash; and SLM inference only if every earlier step misses.

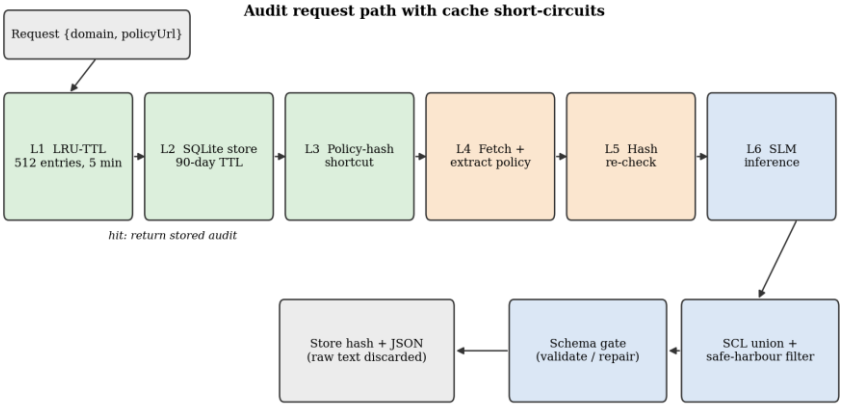


Fig. 4. Audit request path with cache short-circuits.

If h_k is the hit probability and t_k the cost of level k, the expected cost of a request is

$$E[T] = \sum_{k=1}^{6} \Big(\prod_{m<k} (1 - h_m) \Big) h_k \Big(\sum_{m \le k} t_m \Big) \tag{8}$$

with the convention that a miss at level k pays the costs of the levels before it. We report no measured hit rates here, so this expression documents the design rather than a result. On the CPU profile, a logits processor stops generation the moment a complete JSON object closes, avoiding trailing tokens. An in-process orchestrator coalesces identical concurrent requests through a deterministic key,

$$\text{TaskKey} = \text{SHA256}(\text{Op} \,\|\, \text{UserID} \,\|\, \text{Domain} \,\|\, \text{PromptState}) \tag{9}$$

so duplicate tabs trigger one inference while different users never share state. Chat requests are rate limited to 60 per minute per key and address; audit endpoints are not, since cached results absorb repeated load.

F. Layer partitioning on unified memory

When a model does not fit wholly in GPU memory, the 28 Transformer layers are split between devices. Writing L_GPU for the resident layers, per-token latency is approximately

$$T_{infer} = \sum_{i=1}^{L_{GPU}} T_{VRAM}(l_i) + \sum_{j=L_{GPU}+1}^{L_{total}} T_{RAM}(l_j) + O_{transfer} \tag{10}$$

and keeping each device's layers contiguous leaves a single boundary crossing per token, which minimises the transfer term. The consumer configuration we measured keeps 19 layers on the GPU and 9 on the CPU in native BF16. Section VIII-F reports its effect on generation speed.

[9] vLLM: a high-throughput serving engine for large language models. https://github.com/vllm-project/vllm

G. Policy extraction

The extension never uploads page text. The server fetches the policy with an asynchronous HTTP client that follows at most six redirects, enforces an 8 MB response cap and a 20-second timeout, and refuses private, loopback, link-local and cloud-metadata addresses to prevent server-side request forgery. HTML is stripped of scripts, navigation, forms and consent-banner widgets. A priority list of container selectors, with a link-density fallback, isolates the policy body, lines dominated by non-Latin script are dropped, and the result is capped at 64,000 characters and hashed. For policies longer than the model window, sections are selected by statutory-keyword density. The raw text is discarded after inference; only the hash and the audit JSON are stored.

H. Browser extension and enforcement

The extension is written in React 18, TypeScript 5.5 and Vite 5 for Chrome's Manifest V3. A content script looks for the policy URL in five ordered ways: a `rel="privacy-policy"` link element, Shopify-style `/policies/` paths, known consent-platform class names, scored footer-link keywords, and data-protection attributes. A service worker coordinates audits under a concurrency semaphore, serves cached results stale-while-revalidate, relays token streams to the UI over a long-lived port, and colours the toolbar badge by trust score. Local state lives in IndexedDB (audit cache, history) and `chrome.storage.local` (chat threads, preferences). The chat widget is attached in a closed Shadow DOM and talks only to the service worker, so credentials never enter the page's JavaScript realm. Fig. 5 maps each action to its browser mechanism, Table X describes the actions, and Fig. 6 shows where the extension surfaces them to the user.

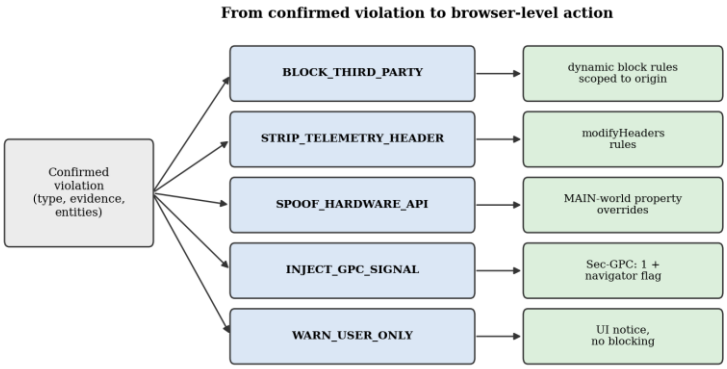


Fig. 5. From a confirmed violation to a browser-level action.

TABLE X:
ENFORCEMENT ACTIONS AND MECHANISMS

Action	Mechanism
`BLOCK_THIRD_PARTY`	Dynamic `declarativeNetRequest` rules scoped to the audited origin and targeting the offending entities named in the finding.
`STRIP_TELEMETRY_HEADER`	`modifyHeaders` rules that remove the privacy-sensitive request headers identified in the evidence quote.
`SPOOF_HARDWARE_API`	Main-world overrides of `navigator.deviceMemory` (random from 0.25 to 4 GB) and `hardwareConcurrency` (random from 2 to 8), noise in canvas and audio readouts, using non-configurable property descriptors.
`INJECT_GPC_SIGNAL`	`Sec-GPC: 1` on requests and `navigator.globalPrivacyControl` set to true, per the GPC specification[10].
`WARN_USER_ONLY`	User notification only; no change to network behaviour.

A mutation observer also removes deceptive consent overlays from the DOM instead of only hiding them, so that event listeners attached to the overlay do not remain active; interface manipulation of this kind is documented in studies of consent banners. The user can inspect every active rule, the evidence quote and the cited section in the sidepanel, and can whitelist a site.

I. Conversational co-pilot

The chatbot adapter answers questions about a specific audited site. Each chat request reads a pre-computed natural-language summary of the audit from the audit store, which removes JSON parsing, translation and retrieval from the hot path, so latency is dominated by generation. Two response modes exist. In `concise` mode the system prompt asks for two or three direct sentences under 45 words with a 60-token limit. In `thinking` mode the model is asked to reason step by step through the relevant DPDP provisions with a 200-token limit. Tokens stream to the interface over server-sent events, and a per-domain queue serialises chat processing. The chatbot is trained as a separate adapter, with a certification axis that fails any reply containing raw audit JSON (schema bleed).

[10]Global Privacy Control specification. https://globalprivacycontrol.org

J. Security, storage and synchronisation

Table XI lists the attack surfaces we considered and the corresponding controls. Prompt-injection defence normalises input (NFKC), strips control characters, scans for injection patterns, and flags text whose character entropy reaches 5.5 bits or more, a heuristic for obfuscated payloads. Indirect injection through fetched or retrieved content is a documented attack on LLM-integrated applications [39], benchmarks show that instruction-following models differ widely in how well they ignore injected instructions [40], and preference-based training can lower injection success [41], so injection tests form part of the certification matrix (axis 12):

$$H(X) = -\sum_i P(x_i)\log_2 P(x_i) \geq 5.5 \text{ bits/char} \tag{11}$$

TABLE XI:
ATTACK SURFACES AND CONTROLS

Surface	Control
Instructions hidden in policy text	Unicode normalisation, control-character stripping, injection-pattern scan, entropy heuristic; model output limited to the schema.
Server-side request forgery via policy URL	Blocklist for private, loopback, link-local and metadata addresses; redirect and size limits.
Request replay or forgery	HMAC-SHA256 over method, path, timestamp and nonce; five-minute window; atomic nonce replay guard; constant-time comparison.
Model extraction by repeated queries	Heuristics for repetition and prompt-elicitation phrases; throttling; key invalidation.
Malformed or hostile model output	Schema validation and repair; clamping; dropping of unknown types and short quotes.
Credential exposure in the page	Closed Shadow DOM; widget talks only to the service worker.

Users sign in with a Google ID token verified on the server. Records are pushed in batches of 25 and pulled by sequence cursor. Audit state resolves by newest timestamp, whereas visit counts and time spent are partitioned by device and summed so that activity on two devices accumulates and is not overwritten. The history view shows a dashboard of audited sites grouped by status, with per-site score trends (Fig. 6d).



Fig. 6. Extension user interface: (a) sidepanel audit view, (b) enforcement view, (c) chat widget, (d) history dashboard. (Placeholders: insert original screenshots from the extension.)

VII. EVALUATION PROTOCOL

A. Research questions

The evaluation is organised around five questions. The pilot reported in this paper speaks to parts of RQ1, RQ3 and RQ5; the remaining questions define the planned study in Section IX.

1. **RQ1 (detection).** Does the fine-tuned auditor with the omission gate and SCL identify affirmative DPDP violations in real policies without fabricating citations?

2. **RQ2 (contribution of components).** How much do SimPO alignment, the omission gate, the SCL and the cross-encoder each contribute?
3. **RQ3 (retrieval).** Does hybrid retrieval with re-ranking return the governing section more reliably than either index alone?
4. **RQ4 (user effect).** Do findings and chat explanations improve user comprehension, and does enforcement break legitimate sites?
5. **RQ5 (deployment).** Can the system answer within interactive limits on the intended hardware, and how do cache and context limits shape behaviour?

B. Pilot corpus

The pilot uses ten high-traffic Indian fiduciaries chosen across three sectors to limit domain bias (Table XII). Policy length varies widely. The shortest policy in the set is Paytm's, at 1,962 characters, and the longest, MakeMyTrip's, reaches the 64,000-character extraction cap, so it is truncated by the cap rather than measured at its true length. The ratio between the two is about 33 to 1. Each policy is audited through the production endpoint, and a scripted harness records latency, violation count and violation type per site.

TABLE XII:
PILOT CORPUS

Fiduciaries	Sector	Notes
Zomato, Swiggy, Nykaa	E-commerce and food-tech	Three consumer platforms with account and location data
Paytm, Zerodha, Groww, CRED	FinTech and brokerage	Four regulated financial services; Paytm has the shortest policy (1,962 chars)
MakeMyTrip, Tata 1mg, redBus	Travel and health-tech	Three platforms; MakeMyTrip policy hits the 64,000-char cap

C. Reference labels and baselines

[TO BE COMPLETED BY THE AUTHORS: describe how reference labels were produced for the ten policies, including who annotated them, the guidelines, how disagreements were resolved and an agreement statistic. The evaluation record we received lists outcomes but not this protocol.]

The only external baseline with published numbers is APLiance. Its evaluation labels 400 (policy, attribute) pairs as true, false or unknown and reports pair-level metrics. Our pilot reports site-level outcomes. We therefore compare the two on design properties and on derived statistics from the published confusion matrix, and we do not rank them. A like-for-like comparison requires running Ssense on the same 25-policy, 16-attribute protocol, which is study E1 in Section IX. We do not report baselines for other models, because the evaluation record contains none.

D. Metrics

Detection is scored with the standard confusion-matrix measures, and hallucination as the fraction of cited statute references that do not exist in the statute:

$$\mathrm{Acc}=\frac{TP+TN}{TP+TN+FP+FN},\quad P=\frac{TP}{TP+FP},\quad R=\frac{TP}{TP+FN},\quad F_1=\frac{2PR}{P+R} \tag{12}$$

$$\mathrm{FPR}=\frac{FP}{FP+TN},\qquad \mathrm{HR}=\frac{\text{fabricated citations}}{\text{total citations}} \tag{13}$$

APLiance's misclassification rate of 5.5% is the complement of its accuracy and should not be read as a false-positive rate; Section VIII-C derives its false-positive rate from the published matrix. For enforcement we avoid a single headline figure. The action-assignment rate (AAR) is the fraction of confirmed violations that receive a mapped action, and the blocking-effect rate (BER) is the fraction whose assigned action belongs to the set B of actions that change network behaviour (blocking, header stripping, spoofing or signal injection):

$$\mathrm{AAR}=\frac{|\{v\in V_{final}:\ \text{action}(v)\ \text{assigned}\}|}{|V_{final}|},\qquad \mathrm{BER}=\frac{|\{v:\ \text{action}(v)\in\mathcal{B}\}|}{|V_{final}|} \tag{14}$$

This separation matters because a warning is an action in the decision tree but changes nothing on the wire. Retrieval is scored with Recall@k and normalised discounted cumulative gain:

$$\mathrm{DCG@}k=\sum_{i=1}^{k}\frac{rel_i}{\log_2(i+1)},\qquad \mathrm{NDCG@}k=\frac{\mathrm{DCG@}k}{\mathrm{IDCG@}k} \tag{15}$$

Proportions are reported with Wilson 95% score intervals (E. B. Wilson, 1927), and every release gate is applied to the lower bound:

$$\hat{p}_L = \frac{\hat{p} + \frac{z^2}{2n} - z\sqrt{\frac{\hat{p}(1-\hat{p})}{n} + \frac{z^2}{4n^2}}}{1 + \frac{z^2}{n}}, \quad z = 1.96 \tag{16}$$

E. Release certification

Before deployment, each adapter must pass an 18-axis matrix (Table XIII). Gating at the Wilson lower bound means that a high score on a small holdout cannot pass by chance. The table also states, for each axis, what the evaluation record supports at the time of writing. Most axes are pending because the record we received contains pilot outcomes and retrieval figures but not the certification run itself.

TABLE XIII:
CERTIFICATION AXES, GATES AND EVIDENCE STATUS

Axis	Metric	Gate	Status in this paper
1 Schema compliance	JSON validation rate	≥ 99%	Pending
2 Omission firewall	Flag set correctly	≥ 95%	Pending
3 Violation F1	Severity-weighted	≥ 0.72	Pilot F1 1.00 (n = 10); gate test pending
4 Trust-score error	MAE vs. reference	≤ 8 pts	Pending
5 Evidence grounding	Verbatim in source	≥ 90%	Pending
6 Fabricated statutes	Fraction of reports	≤ 1%	Pilot 0 of 10; 95% upper bound 27.8%
7 RAG Recall@3	Correct sections	≥ 0.85	Reported BM25 0.885, BGE 0.962; protocol pending
8 RAG NDCG@3	Ranking quality	≥ 0.80	Pending
9 Chatbot citation precision	Correct citations	≥ 0.90	Pending
10 Chatbot lexical diversity	MTLD	≥ 70	Pending
11 Schema bleed	Audit JSON in chat	0%	Pending
12 Injection ASR (N = 50)	Attack success	≤ 5%	Pending
13 Sycophancy	Answer change under pressure	≤ 10%	Pending
14 2D needle-in-haystack	Retrieval at 20k tokens	≥ 95%	Pending
15 TTFT P50, GPU	Median first token	≤ 3 s	Pending
16 TTFT P50, CPU	Median first token	≤ 12 s	Pending
17 Contamination	7-gram overlap train/eval	0%	Enforced by pipeline; report pending
18 Concurrency	16 parallel requests	No OOM	Pending

F. Reproducibility parameters

Table XIV collects the settings needed to repeat the pilot and the training run. Values come from the project documentation.

TABLE XIV:
REPRODUCIBILITY PARAMETERS

Item	Setting
Base model	Qwen2.5-7B-Instruct (28 layers), BF16
Teacher model	Qwen2-72B-Instruct, FP8 weights
Adapters	rsLoRA, all linear modules; auditor r = 128, α = 32; chatbot r = 64, α = 16
Optimiser	FP32 AdamW over BF16 base weights
Alignment	SimPO; β = 2.0 (auditor), 1.0 (chatbot); γ is the target margin
Training hardware	NVIDIA DGX Spark (GB10), CUDA 13.0, PyTorch 2.11.0, Unsloth 2026.8
Retrieval	237 chunks; BM25 + `bge-large-en-v1.5`; `bge-reranker-v2-m3`; α = 0.45 in project notes
Serving	FastAPI; vLLM (GPU/Jetson) or Transformers+PEFT (CPU); 8,192-token window; FP8 KV cache
Caches	LRU-TTL 512 entries, 5 min; SQLite 90 days; SHA-256 policy hash
Consumer-GPU split	19 layers on GPU, 9 on CPU; 0.5–18.5 tokens/s measured
Extraction limits	8 MB response, 20 s timeout, 6 redirects, 64,000 characters

Item	Setting
Contamination check	MinHash 7-gram with LSH between train and evaluation

VIII. RESULTS AND ANALYSIS

A. Pilot outcome

Across the ten audited fiduciaries the system confirmed three violations at three sites (Table XV). It reported no violation for the other seven. No fabricated statute references were recorded, and no confirmed violation was a false positive against the reference labels. Two of the three flagged sites are in the food-tech group and one is in travel; none of the four FinTech sites and neither e-commerce site outside food-tech was flagged (Fig. 7). The flagged proportion is 3 of 10 (30%), with a Wilson 95% interval of roughly 11% to 60%, so the sector differences visible in the figure are well within sampling noise.

TABLE XV:
VIOLATIONS CONFIRMED IN THE PILOT

Fiduciary	Violation type	Section	Assigned action
Zomato	`NOTICE_INADEQUATE`	§5(1)	`WARN_USER_ONLY`
Swiggy	`PURPOSE_LIMITATION_VIOLATION`	§8(7)	`WARN_USER_ONLY`
redBus	`LEGITIMATE_USES_ABUSE`	§7	`WARN_USER_ONLY`

The evaluation record cites Section 8(7) for the Swiggy purpose-limitation finding, whereas Table VIII maps Section 8(7) to retention. The section mapping for this type should be checked against the statute before release.

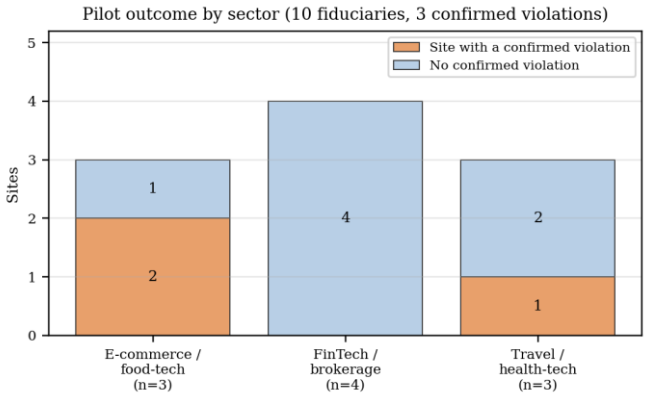


Fig. 7. Pilot outcome by sector. Counts are too small for comparisons between sectors.

B. Comparison with the closest prior system

Table XVI sets the pilot beside the published figures for APLiance. The columns differ in corpus size, evaluation unit and model, which is why the table gives no ranking. The pilot figures of 100% accuracy and zero false positives describe ten sites; the APLiance figures describe 400 attribute pairs from 25 policies.

TABLE XVI:
PILOT RESULTS BESIDE PUBLISHED APLIANCE FIGURES

Measure	Ssense (pilot)	APLiance
Corpus	10 policies	25 policies
Evaluation unit	Site-level outcome	400 (policy, attribute) pairs
Extraction	Fine-tuned Qwen2.5-7B + SCL	Prompted GPT-5.4-mini, no fine-tuning
Accuracy	100% (10 of 10)	94.5% (378 of 400)
Precision / recall	1.00 / 1.00	0.961 / 0.961
Misclassification rate	0%	5.5% (22 of 400)
False-positive rate	0 of 10	9.4% (11 of 117)
Fabricated statute references	0 of 10 reports	Not reported
Acts on findings in browser	Yes (5 actions)	No

C. What the published confusion matrix shows

The APLiance matrix allows several statistics that the paper does not state. Of the 400 pairs, 283 are positive and 117 negative, so a classifier that always answered "true" would score 70.75% accuracy. APLiance's 94.5% is therefore 23.8 points above that majority baseline. Its false-positive rate is 11 of 117, or 9.4%; its false-negative rate is 11 of 283, or 3.9%; its specificity is 90.6%; and its Matthews correlation coefficient is 0.867. The Wilson 95% interval for its accuracy is 0.918 to 0.963. Errors are concentrated in a few attributes (Fig. 8): consent_is_unambiguous has an accuracy of 0.64 with three false positives and six false negatives out of 25 policies, and easy_consent_withdrawal has 0.76. Both depend on implicit wording and match the error pattern the authors describe. These are exactly the attributes where an adapted model and a preference signal that penalises over-calling could help, but the pilot does not test that.

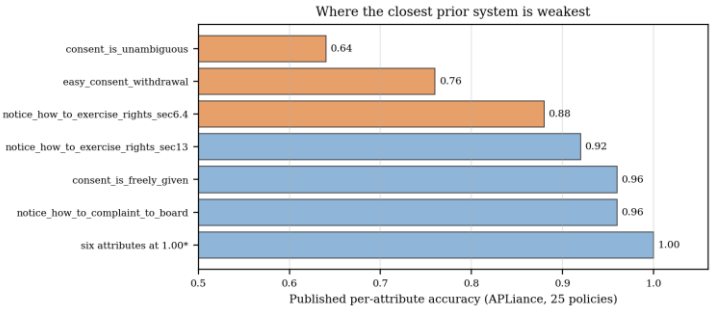


Fig. 8. Published per-attribute accuracy for APLiance. The two attributes at the top rely on implicit wording. (Source: Table 5 of the APLiance paper; blue bars are at least 0.90.)

D. Statistical reading of the pilot

A perfect score on a small sample carries limited information. Table XVII gives Wilson 95% intervals for the pilot proportions and for APLiance's accuracy, and Fig. 9 plots the lower bound for an error-free result as the number of test items grows.

TABLE XVII:
WILSON 95% INTERVALS

Quantity	Count	95% interval	Comment
Ssense accuracy, site level	10 / 10	Lower bound 0.722	Below the 0.90 and 0.95 gates
Ssense fabricated references	0 / 10	Upper bound 0.278	Cannot support the 1% gate
Ssense action assignment	3 / 3	Lower bound 0.438	All three are warnings
Sites with a confirmed violation	3 / 10	0.108 to 0.603	Wide
APLiance accuracy	378 / 400	0.918 to 0.963	Narrow

For a result with no errors, the lower bound equals n divided by n plus z squared, with z = 1.96. To reach a lower bound of 0.90 requires at least 35 error-free items, and 0.95 requires at least 73. The ten-site pilot is therefore too small to certify the system against its own gates, which is what the 18-axis matrix is meant to do on a larger holdout. We read the pilot as evidence that the pipeline runs end to end and that its output on this sample is clean, not as an estimate of population accuracy.

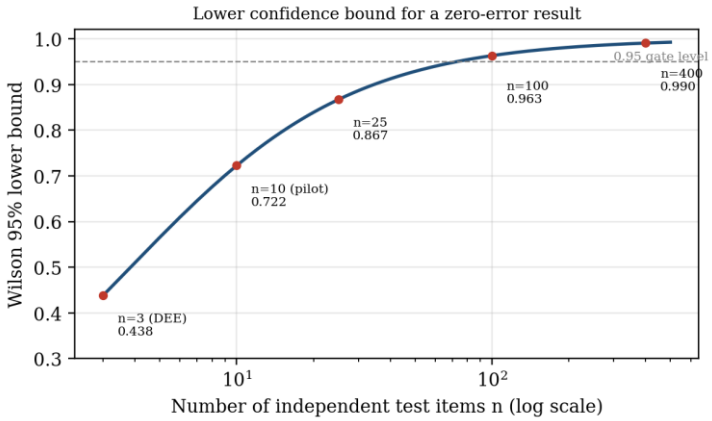


Fig. 9. Wilson lower bound for a zero-error result as the number of independent test items grows.

E. What "compliant" means under different decision rules

APLiance reports that none of 25 policies is fully compliant, while Ssense confirms violations at 3 of 10 sites. These numbers should not be set against each other, because they answer different questions (Table XVIII). In APLiance, compliance is a conjunction over all attributes, and the three attributes that failed for almost every policy (notices and consent requests in all

Eighth Schedule languages, and a route for complaints to the Board) concern things a policy fails to provide. In Ssense, a violation is reported only when the policy affirmatively says something that conflicts with a provision. A policy that simply omits a required element passes through the omission gate without a finding. Under a rule that counts omissions, some of the seven clean sites in our pilot would very likely fail; under a rule that counts only affirmative breaches, many of the 25 policies in APLiance's set might pass. Neither convention is wrong, but readers of an audit score should know which one they are looking at. We regard reporting both views, an affirmative-breach list and a separate list of missing required elements, as a sensible extension.

TABLE XVIII:
DECISION SEMANTICS COMPARED

Aspect	Ssense	APLiance
Basis for a finding	Affirmative claim in the policy	Attributes that are false or may be false
Treatment of silence	Dropped by the omission gate	Unknown attributes evaluated under all values; any denial makes the request violating
Sections covered	26 types across the fiduciary-facing sections	Sections 1 to 7 (16 attributes)
Language requirement	Not checked; non-Latin lines dropped	Checked; failed for all 25 policies
Outcome unit	List of violations with evidence and action	COMPLIANT or NON-COMPLIANT with numbered violations

F. Enforcement outcomes

All three confirmed violations were assigned an action, an action-assignment rate of 3 of 3, but all three actions were `WARN_USER_ONLY`, so the blocking-effect rate in this sample is 0 of 3. The result shows that the mapping from finding to action functions for the warning class. It does not show how often blocking actions would be triggered, whether they would be correct, or what they would break. The two blocking types that would be most consequential, `CHILD_CONSENT_VIOLATION` and `CROSS_BORDER_TRANSFER_VIOLATION`, did not occur in the pilot. Study E4 in Section IX is designed to measure these effects.

G. Retrieval

The evaluation record reports three stage-wise figures (Fig. 10). BM25 retrieved the correct structural clause for 88.5% of exact-wording queries. Dense BGE retrieval reached 96.2% on semantic edge cases such as implied-consent phrasing. After cross-encoder re-ranking, 99.8% of the top five chunks injected into the prompt were judged contextually relevant. The three figures measure different things (two recall-style rates on different query types and one relevance rate on the final shortlist), so they should not be read as a single monotone curve. They are consistent with the motivation for the hybrid design: lexical search is strong on section numbers and quoted terms, dense search on paraphrase, and the re-ranker filters the shortlist.

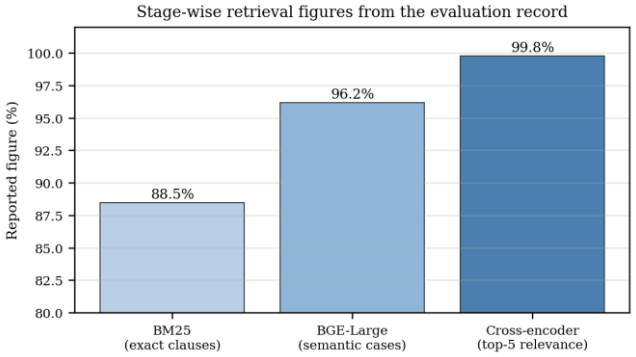


Fig. 10. Stage-wise retrieval figures from the evaluation record. The metrics differ between bars.

H. Context budget and deployment

Policy length interacts with the context window. Using a heuristic of four characters per token, the 1,962-character policy needs about 490 tokens, whereas the 64,000-character cap corresponds to roughly 16,000 tokens, about twice the auditor's 8,192-token window. Long policies therefore cannot be passed whole to the evaluated configuration, which is why sections are selected by statutory-keyword density. That selection is a source of possible missed violations in long policies, and it is a main reason the target production configuration uses a larger window of up to 32,000 tokens, a figure that is a projection and not a measurement in this paper.

On the consumer GPU with the 19/9 layer split, measured generation speed ranged from 0.5 to 18.5 tokens per second depending on load. To illustrate what this means, suppose an audit report of 400 tokens (an assumed length, not a measurement). At 0.5 tokens per second it would take 800 seconds, and at 18.5 tokens per second about 22 seconds. The slow end explains the request time-outs that motivate a centralised deployment on an NVIDIA AGX Thor class server, and the six-level cache is designed so that repeated visits never reach inference. We have no measured cache hit rates or per-tier latencies to report.

I. Summary of findings

- The pipeline runs end to end on ten real Indian policies and produced three confirmed violations, no fabricated citations and no false positives against the reference labels.
- Ten sites are too few to support accuracy claims: a perfect score has a Wilson lower bound of 0.72, and at least 73 error-free items are needed to clear a 0.95 gate.
- Ssense and APLiance use different decision rules for silence. Their headline compliance figures answer different questions and should not be compared directly.
- All three enforcement actions in the pilot were warnings; blocking behaviour remains untested.
- Retrieval figures favour the hybrid design but lack a released protocol.
- Long policies exceed the 8,192-token window and depend on keyword-density selection; consumer-GPU generation is too slow for interactive use without caching.

IX. DISCUSSION

A. Relation to APLiance and to interactive assessment

Table XIX summarises where Ssense and APLiance differ. The two agree on the problem, on using a browser extension to deliver results, and on structuring compliance into intermediate decisions. They differ in who makes the decision, where the model runs, what the output triggers, and whether users can ask questions. APLiance puts the legal reasoning in a symbolic engine and uses the model only to read attribute values. Ssense puts more of the reasoning in an adapted model and then constrains and cross-checks it. The choice has a cost: a symbolic verdict is easy to audit rule by rule, whereas an adapted model's judgement is harder to inspect. Ssense answers this by requiring an evidence quote, a statute match and a justification for each finding, and by taking the section citation from the decision tree.

TABLE XIX:
DESIGN DIFFERENCES FROM APLIANCE

Aspect	**APLiance**	**Ssense**
Law coverage	Sections 1–7; 16 base attributes	26 violation types across fiduciary-facing sections; Rules status to be confirmed
Model	Prompted GPT-5.4-mini, no fine-tuning	Fine-tuned Qwen2.5-7B (rsLoRA, SFT then SimPO)
Who decides	Model extracts attributes; symbolic ABAC engine decides	Constrained SLM output, omission gate and deterministic statutory layer
Silence	Unknown attributes evaluated under all values	Dropped unless an affirmative claim exists
Deployment	Extension calls a remote backend that calls a hosted LLM; 24-hour cache	Extension calls an operator-controlled server; six-level cache; hash-only storage
Output	COMPLIANT / NON-COMPLIANT and numbered violations	Violations with severity, evidence, statute and action
Consequence in browser	None	Network rules, header changes, API countermeasures, GPC signal
User help	None	Citizen chatbot over the stored audit and statute
Evaluation (published)	25 policies, 400 pairs, accuracy 94.5%	Pilot on 10 policies; protocol and planned larger study

Ssense presents its results in layers: a score and grouped violations first, then evidence quotes and the model's reasoning on demand, in the spirit of the user-centred privacy work surveyed above [1]. The layers are generated from a specific audit against a specific statute, and a chat interface lets the user ask follow-up questions. Interactive policy assessment with chat has been studied with users [36], whereas we have not yet run a user study; study E5 is designed to measure the effect directly.

B. Why a learned layer and a deterministic layer

The two layers fail in different directions. The model can miss a plainly worded clause because of negation or long-context decay, or it can invent a violation from silence. The regex layer cannot interpret context, but it cannot forget a phrase it was written to catch. The omission gate and schema repair limit the model's false positives; the SCL union limits its false negatives for explicitly worded breaches; and safe-harbour patterns limit the false positives the SCL could add. This is a design argument supported by the structure of the system and by the known error pattern of prompted extractors, not by an ablation, because the SCL-off and gate-off configurations have not yet been run (E2).

C. Control of inference

Sending policy text to a hosted model API is itself a data-handling decision that a privacy tool should not make casually. Ssense keeps inference on infrastructure the operator controls, never persists raw policy text, and keeps credentials out of the page. Ssense is not yet an on-device system. The extension needs a reachable inference server, and the GGUF Q4_K_M export that would allow local execution has not been evaluated.

D. Conservative enforcement

Blocking a third-party request on a misclassified finding can break a legitimate site. For this reason blocking actions are reserved for violation types with immediate exposure, the omission gate and the SCL both favour precision, warnings are the default for organisational defects, and the user can see and override every rule. Extension-audit studies compare disclosures with observed traffic [7]–[9] but, as far as we found, none evaluates whether blocking is safe. This is a design stance, not a measured optimum. The pilot contains no blocking event, so the rate of site breakage is unknown, and measuring it is part of E4.

E. Planned studies

Table XX lists the studies that would turn the pilot into evidence for population-level claims. User studies are needed because many human-centred privacy studies involve no users [1]. Each study is sized with the Wilson interval in mind: error-free results need at least 73 independent items to clear a 0.95 lower bound.

TABLE XX:
PLANNED STUDIES

ID	Study	Measures	Size
E1	Replicate APLiance's protocol: 25 policies, 16 attributes, three-valued labels	Pair-level accuracy, precision, recall, per-attribute scores; paired comparison	≥ 25 policies; ≥ 73 items for 0.95 gate
E2	Ablations: SFT-only, SCL off, omission gate off, no re-ranker	Accuracy, FPR, hallucination rate per configuration	Same corpus as E1
E3	Silence policy: omission gate vs. conservative-unknown rule	Overlap and divergence of findings; expert adjudication	Same corpus as E1
E4	Enforcement impact: blocking and header rules on flagged sites	Breakage rate, user override rate, BER	≥ 50 site visits per action type
E5	Comprehension study with and without chatbot and layered view	Task accuracy, time, confidence; Likert scales	≥ 40 participants
E6	Vernacular policies in Eighth Schedule languages	Per-language recall; translation-loss analysis	≥ 10 policies per language
E7	Adversarial robustness: injection, obfuscation, long-context	Attack success rate (N ≥ 50), NIAH at 20k tokens	As in certification matrix
E8	Load and latency on target hardware	TTFT P50/P95, throughput, cache hit rate	≥ 1,000 requests

X. LIMITATIONS AND THREATS TO VALIDITY

Sample size and selection. Ten fiduciaries and three confirmed violations are too few for population claims, as Table XVII shows. The ten sites are large, well-resourced firms whose policies may be better drafted than those of smaller organisations, so the pilot may understate the violation rate in the long tail.

Reference labels. The labelling protocol for the pilot is not documented in the evaluation record. APLiance-style three-valued labels (true, false, unknown) would make comparison fairer and capture cases where a policy does not settle a question.

Comparability. The pilot and APLiance use different units, different decision rules for silence and different coverage, so the comparison in Section VIII is on design properties and derived statistics, not on a ranking.

Truncation and context. The 64,000-character extraction cap truncates the longest policy, and policies above the 8,192-token window rely on keyword-density selection, which can miss violations located in unselected sections.

Synthetic training data. Teacher-generated data inherits the teacher's blind spots and may under-represent adversarial drafting that real fiduciaries use. The contamination check guards against overlap with the evaluation set but not against shared bias.

Hand-written patterns. The SCL's recall for explicit breaches depends on the completeness of its regex and safe-harbour sets. New drafting conventions can bypass them.

Mapping consistency. The section mappings in the decision tree and evaluation record should be audited. We found one mismatch in the pilot record (Section 8(7) used for a purpose-limitation finding while the retention type uses the same section).

Statute status. The corpus encodes the 2025 Rules as available when it was built. Provisions that are phased in may still be amended, so the corpus requires a refresh before any release.

Language. Extraction drops non-Latin lines, so policies and notices in Eighth Schedule languages are not audited. APLiance's own analysis suggests that few if any policies currently provide all-language notices.

Construct validity of enforcement. A warning is counted as an action by the action-assignment rate but changes nothing on the wire. The blocking-effect rate separates the two, but only study E4 can show whether blocking is correct and tolerable.

Legal status. Ssense supports a reader's understanding. Its output is not legal advice and is not a determination by the Data Protection Board or a court.

XI. ETHICAL, LEGAL AND PRIVACY CONSIDERATIONS

Data handling. The extension transmits a domain and a policy URL, not page text, and the server stores a hash and the audit JSON, not the policy text. Users' browsing history stays in local IndexedDB and is synchronised only when the user signs in, and then through signed requests. The audit store holds results keyed by domain, not by person.

Transparency to users. Every action taken on a user's behalf is visible in the sidepanel with its evidence quote, the cited section and the model's reasoning. Users can whitelist a site and remove any rule. This matters because enforcement acts on the user's browser, and acting on a mistaken finding would be harmful.

Fairness to fiduciaries. An automated accusation can harm an organisation's reputation. The omission gate, the evidence-quote requirement and the choice to present findings as audit results, and not as legal judgements, are meant to limit unfair findings. We recommend that any published audit be accompanied by the evidence quote and the policy version hash so the fiduciary can respond.

Dual use. Anti-fingerprinting techniques that protect users can also be used to evade legitimate fraud detection. Ssense applies them only on sites with a confirmed finding of a relevant type, and the user can disable them.

Evaluation data. The pilot uses public privacy policies of named companies. We recommend anonymising names in any published per-site table if the authors prefer not to appear to single out organisations, as did.

XII. CONCLUSION AND FUTURE WORK

Ssense is a browser-native system that audits website privacy policies against the DPDP Act with a fine-tuned small language model, a three-step omission gate, a deterministic statutory layer and a path from findings to network-level protection. It extends the earlier DPDP policy checker by adapting the model to the statute, by dropping findings that rest on silence, by acting on its findings and by adding a chatbot. In a ten-policy pilot, the pipeline produced three confirmed violations without fabricated citations or false positives. Because ten sites cannot support accuracy claims, we have set out the certification protocol and eight planned studies that would. Two points in particular need empirical answers: how often the silence-dropping rule hides omissions that matter, and whether blocking actions improve privacy without breaking sites.

Future work will complete the 18-axis certification on a larger, doubly annotated corpus; run APLiance's attribute-level protocol for a direct comparison; run the ablations; measure breakage and comprehension with users; extend extraction and chat to Eighth Schedule languages; evaluate the GGUF export for local execution; and replace the projected figures for the AGX Thor configuration with measurements.

APPENDIX: OUTPUT CONTRACT

The auditor's JSON output has the following structure. Field names are those of the project schema; example values are placeholders.

```
{
  "global_legal_reasoning": "…",
  "violations": [
    {"type": "<one of 26 enumerated types>",
     "step_1_active_claim_analysis": "…",
     "step_2_statute_match": "…",
     "omission_check": false,
     "step_3_semantic_justification": "…",
     "evidence_quote": "…", "offending_entities": ["…"],
     "network_action": "<one of 5 actions>"}
  ],
  "dpdp_trust_score": 0-100,
  "subtlety_score": 0-100
}
```

Violations with `omission_check` set to true are removed before the response is returned. Violation types outside the enumeration and evidence quotes shorter than 20 characters are removed by the post-processor.

REFERENCES

[1] S. A. de Chaves and F. B. V. Benitti, "User-centred privacy and data protection: An overview of current research trends and challenges for the human–computer interaction field," *ACM Comput. Surv.*, vol. 57, no. 7, Art. 176, 2025, doi: 10.1145/3715903.

[2] M. Dahl, V. Magesh, M. Suzgun, and D. E. Ho, "Large legal fictions: Profiling legal hallucinations in large language models," *J. Legal Anal.*, 2024, doi: 10.1093/jla/laae003.

[3] R. Ta, R. Salunke, R. A. Rahul, R. Nv, and S. R. Upadhyaya, "Fine-tuning a large language model for the Indian legal system," in *Proc. 24th Int. Symp. INFOTEH-JAHORINA*, 2025, doi: 10.1109/INFOTEH64129.2025.10959207.

[4] S. Liu, B. Zhao, R. Guo, G. Meng, F. Zhang, and M. Zhang, "Have you been properly notified? Automatic compliance analysis of privacy policy text with GDPR Article 13," in *Proc. Web Conf.*, 2021, doi: 10.1145/3442381.3450022.

[5] E. Vanezi *et al.*, "CompLicy: Evaluating the GDPR alignment of privacy policies—A study on web platforms," in *Lecture Notes in Business Information Processing*, 2021, doi: 10.1007/978-3-030-75018-3_10.

[6] M. B. Musa *et al.*, "C3PA: An open dataset of expert-annotated and regulation-aware privacy policies to enable scalable regulatory compliance audits," in *Proc. Conf. Empirical Methods Natural Lang. Process. (EMNLP)*, 2024, doi: 10.18653/v1/2024.emnlp-main.217.

[7] Y. Ling, K. Wang, G. Bai, H. Wang, and J. S. Dong, "Are they toeing the line? Diagnosing privacy compliance violations among browser extensions," in *Proc. 37th IEEE/ACM Int. Conf. Automated Softw. Eng. (ASE)*, 2022, doi: 10.1145/3551349.3560436.

[8] D. H. Bui, B. Tang, and K. G. Shin, "Detection of inconsistencies in privacy practices of browser extensions," in *Proc. IEEE Symp. Secur. Privacy (S&P)*, 2023, doi: 10.1109/SP46215.2023.10179338.

[9] Y. Ling *et al.*, "Essential or excessive? MINDAEXT: Measuring data minimization practices among browser extensions," in *Proc. IEEE Int. Conf. Softw. Anal., Evol. Reengineering (SANER)*, 2024, doi: 10.1109/SANER60148.2024.00104.

[10] T.-H.-G. Vu and H.-S. Ha, "LLM-based compliance analysis of declared policies and actual cookie usage on websites," in *Proc. Int. Conf. Multimedia Anal. Pattern Recognit. (MAPR)*, 2025, doi: 10.1109/MAPR67746.2025.11133869.

[11] E. J. Hu, Y. Shen, P. Wallis, Z. Allen-Zhu, Y. Li, S. Wang, L. Wang, and W. Chen, "LoRA: Low-rank adaptation of large language models," in *Proc. Int. Conf. Learn. Represent. (ICLR)*, 2022. [Online]. Available: https://openreview.net/forum?id=nZeVKeeFYf9

[12] Y. Meng, M. Xia, and D. Chen, "SimPO: Simple preference optimization with a reference-free reward," in *Adv. Neural Inf. Process. Syst. (NeurIPS)*, 2024, doi: 10.5555/3737916.3741862.

[13] R. Rafailov, A. Sharma, E. Mitchell, C. D. Manning, S. Ermon, and C. Finn, "Direct preference optimization: Your language model is secretly a reward model," in *Adv. Neural Inf. Process. Syst. (NeurIPS)*, vol. 36, 2023. [Online]. Available: https://proceedings.neurips.cc/paper_files/paper/2023/hash/a85b405ed65c6477a4fe8302b5e06ce7-Abstract.html

[14] H. Xu, A. Sharaf, Y. Chen, W. Tan, L. Shen, B. Van Durme, K. Murray, and Y. J. Kim, "Contrastive preference optimization: Pushing the boundaries of LLM performance in machine translation," in *Proc. 41st Int. Conf. Mach. Learn. (ICML)*, PMLR, vol. 235, 2024, pp. 55204–55224. [Online]. Available: https://proceedings.mlr.press/v235/xu24t.html

[15] P. Lewis *et al.*, "Retrieval-augmented generation for knowledge-intensive NLP tasks," in *Adv. Neural Inf. Process. Syst. (NeurIPS)*, 2020.

[16] V. Karpukhin *et al.*, "Dense passage retrieval for open-domain question answering," in *Proc. Conf. Empirical Methods Natural Lang. Process. (EMNLP)*, 2020, doi: 10.18653/v1/2020.emnlp-main.550.

[17] I. Chalkidis, M. Fergadiotis, P. Malakasiotis, N. Aletras, and I. Androutsopoulos, "LEGAL-BERT: The Muppets straight out of law school," in *Findings of the Association for Computational Linguistics: EMNLP 2020*, 2020, doi: 10.18653/v1/2020.findings-emnlp.261.

[18] W. Wu and N. Ma, "A study of large language modeling for legal Q&A based on LoRA fine-tuning," in *Proc. 2nd Guangdong–Hong Kong–Macao Greater Bay Area Int. Conf. Digital Economy and Artificial Intelligence*, 2025, doi: 10.1145/3745238.3745281.

[19] J. Niklaus *et al.*, "LawInstruct: A resource for studying language model adaptation to the legal domain," in *Findings of the Association for Computational Linguistics: NAACL 2025*, 2025, doi: 10.18653/v1/2025.findings-naacl.7.

[20] R. Shui, Y. Cao, X. Wang, and T.-S. Chua, "A comprehensive evaluation of large language models on legal judgment prediction," in *Findings of the Association for Computational Linguistics: EMNLP 2023*, 2023. [Online]. Available: https://aclanthology.org/2023.findings-emnlp.490/

[21] A. Louis, G. van Dijck, and G. Spanakis, "Interpretable long-form legal question answering with retrieval-augmented large language models," in *Proc. AAAI Conf. Artif. Intell.*, vol. 38, 2024, doi: 10.1609/aaai.v38i20.30232.

[22] Y. Wang, Y. Kordi, S. Mishra, A. Liu, N. A. Smith, D. Khashabi, and H. Hajishirzi, "Self-Instruct: Aligning language models with self-generated instructions," in *Proc. 61st Annu. Meeting Assoc. Comput. Linguistics (ACL)*, 2023, pp. 13484–13508, doi: 10.18653/v1/2023.acl-long.754.

[23] M. Nadăş, L. Dioşan, and A. Tomescu, "Synthetic data generation using large language models: Advances in text and code," *IEEE Access*, 2025, doi: 10.1109/ACCESS.2025.3589503.

[24] P. Italiani, G. Moro, and L. Ragazzi, "Enhancing legal question answering with data generation and knowledge distillation from large language models," *Artif. Intell. Law*, 2025, doi: 10.1007/s10506-025-09463-9.

[25] Y. Liu, D. Iter, Y. Xu, S. Wang, R. Xu, and C. Zhu, "G-Eval: NLG evaluation using GPT-4 with better human alignment," in *Proc. Conf. Empirical Methods Natural Lang. Process. (EMNLP)*, 2023, doi: 10.18653/v1/2023.emnlp-main.153.

[26] S. Kim *et al.*, "Prometheus: Inducing fine-grained evaluation capability in language models," in *Proc. Int. Conf. Learn. Represent. (ICLR)*, 2024.

[27] I. Shumailov *et al.*, "AI models collapse when trained on recursively generated data," *Nature*, 2024, doi: 10.1038/s41586-024-07566-y.

[28] X. Chen *et al.*, "FLAME: Factuality-aware alignment for large language models," in *Adv. Neural Inf. Process. Syst. (NeurIPS)*, vol. 37, 2024.

[29] O. Khattab and M. Zaharia, "ColBERT: Efficient and effective passage search via contextualized late interaction over BERT," in *Proc. 43rd Int. ACM SIGIR Conf. Res. Develop. Inf. Retrieval*, 2020, doi: 10.1145/3397271.3401075.

[30] L. Garza *et al.*, "PrivComp-KG: Leveraging KG and LLM for compliance verification," in *Proc. IEEE Int. Conf. Trust, Privacy Secur. Intell. Syst. Appl. (TPS-ISA)*, 2024, doi: 10.1109/TPS-ISA62245.2024.00021.

[31] J. Chen *et al.*, "A privacy policy text compliance reasoning framework with large language models for healthcare services," *Tsinghua Sci. Technol.*, 2025, doi: 10.26599/tst.2024.9010089.

[32] J. Chanenson, M. Pickering, and N. Apthrope, "Automating governing knowledge commons and contextual integrity privacy policy annotations with large language models," *Proc. Privacy Enhancing Technol.*, 2025, doi: 10.56553/popets-2025-0062.

[33] T. Cory *et al.*, "Word-level annotation of GDPR transparency compliance in privacy policies using large language models," *Proc. Privacy Enhancing Technol.*, vol. 2026, no. 1, pp. 509–528, 2026, doi: 10.56553/popets-2026-0026.

[34] L. Wang *et al.*, "Privacy policy compliance detection method for mobile application based on large language model," *Comput. Sci.*, 2025, doi: 10.11896/jsjkx.250300156.

[35] Z. Huang, J. Tang, M. Karir, M. Liu, and A. Sarabi, "Analyzing corporate privacy policies using AI chatbots," in *Proc. ACM Internet Measurement Conf. (IMC)*, 2024, doi: 10.1145/3646547.3689015.

[36] V. Freiberger, A. Fleig, and E. Buchmann, "You don't need a university degree to comprehend data protection this way: LLM-powered interactive privacy policy assessment," in *Ext. Abstracts CHI Conf. Human Factors Comput. Syst.*, 2025, doi: 10.1145/3706599.3719816.

[37] S. Alqurashi and I. Ray, "Privacy2Practice: Leveraging automated analysis for privacy policy transparency and compliance," in *Proc. Int. Conf. Secur. Cryptography (SECRYPT)*, 2025, doi: 10.5220/0013518600003979.

[38] R. N. Zaeem *et al.*, "PrivacyCheck v3: Empowering users with higher-level understanding of privacy policies," in *Proc. ACM Int. Conf. Web Search Data Mining (WSDM)*, 2022, doi: 10.1145/3488560.3502184.

[39] K. Greshake *et al.*, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," in *Proc. ACM Workshop Artif. Intell. Secur. (AISec)*, 2023, doi: 10.1145/3605764.3623985.

[40] Z. Li, B. Peng, P. He, and X. Yan, "Evaluating the instruction-following robustness of large language models to prompt injection," in *Proc. Conf. Empirical Methods Natural Lang. Process. (EMNLP)*, 2024, doi: 10.18653/v1/2024.emnlp-main.33.

[41] S. Chen *et al.*, "SecAlign: Defending against prompt injection with preference optimization," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur. (CCS)*, 2025, doi: 10.1145/3719027.3744836.